

Flatcar Security

Source section: `security/` (split out from `setup/` in the refactored branch into its own top-level section). Covers encryption, hardening, certificate/auth, and supply chain security.

Built-in Security Properties

- `/usr` is read-only and dm-verity protected at boot
- No package manager — minimal attack surface
- Only `sshd` (port 22) listens by default
- Default user `core` has wheel/sudo access
- Atomic updates mean security patches apply to the full OS atomically

Encryption (`security/encryption/`)

LUKS Disk Encryption

Full-disk encryption configured via Ignition/Butane at first boot. Clevis can be used for network-bound disk encryption (NBDE).

SELinux

SELinux is supported. **Known issue:** Flannel >0.17.0 does not work with enforced SELinux ([flatcar#779](#)).

Hardening (`security/hardening/`)

General Hardening Guide

Default listening surface is minimal (only sshd). Key hardening steps:

Disable sshd if not needed:

```
systemctl mask sshd.socket --now
```

Restrict `core` user sudo (require password, but don't set one):

```
variant: flatcar
version: 1.0.0
storage:
  files:
```

```
- path: /etc/sudoers.d/core-passwd
mode: 0640
contents:
  inline: |
    core    ALL=(ALL)    ALL
```

With no password set, `sudo` is effectively blocked.

Disable `core` user login entirely:

```
passwd:
  users:
    - name: core
      shell: /sbin/nologin
```

FIPS

Available in Flatcar LTS edition. Enable via `security/hardening/fips.md`.

Disabling SMT (Simultaneous Multithreading)

Mitigates CPU side-channel attacks (Spectre/MDS class). Add `nosmt` to kernel cmdline via Butane `kernel_arguments`.

Audit Subsystem

`auditd` available. Configure via `security/hardening/audit.md`.

Trusted Computing Hardware Requirements

TPM requirements and trusted boot configuration: `security/hardening/trusted-computing-hardware-requirements.md`.

Certificate Authority & Auth (`security/cert-auth/`)

Topic	Notes
Adding custom CAs	Drop PEM files into <code>/etc/ssl/certs/</code> via Butane
Customizing sshd	<code>/etc/ssh/sshd_config.d/</code> drop-in configs
Self-signed certs	<code>cfssl</code> tooling
SSSD	Centralized auth: Active Directory, LDAP integration
etcd unit customization	TLS configuration for etcd via unit drop-ins

Adding a custom CA via Butane:

```
variant: flatcar
version: 1.0.0
storage:
  files:
    - path: /etc/ssl/certs/my-corp-ca.pem
      mode: 0644
      contents:
        inline: |
          -----BEGIN CERTIFICATE-----
          ...
          -----END CERTIFICATE-----
```

Supply Chain Security (security/supply-chain.md)

Flatcar self-assesses at **SLSA Level 3**, working toward Level 4.

Key properties:

- All sources version-controlled with verified history and two-person review
- Scripted, service-based, ephemeral, isolated, build-as-code builds
- Provenance available, authenticated, and non-falsifiable
- Dependencies complete
- SPDX SBOM published with each release
- dm-verity protects the OS partition at runtime

Gaps toward Level 4:

- Hermetic builds (build infrastructure doesn't enforce network isolation yet)
- Security/superuser controls not fully formalized

Constants and IDs (security/constants-and-ids.md)

Well-known GUIDs and identifiers used in Flatcar:

- Disk partition type GUIDs (USR-A, USR-B, ROOT-A, ROOT-B, OEM, EFI)
- OEM IDs used in `flatcar.oem.id` kernel parameter
- Platform identifiers used by Ignition and Afterburn